

Sorso

Spazio di team: guida all'integrazione

Per chi sviluppa il sito che incorpora lo spazio di team: come far accedere i tuoi utenti, come incorporare la pagina e come leggere i risultati dal tuo server.

Versione della guida	1.0 — 7 ottobre 2026
API	v1 (sola lettura)
Indirizzo di Sorso	https://sorso-taccuino.vercel.app
Cosa serve per cominciare	ID partner, segreto di firma e chiave API (te li consegniamo noi)

Indice

1. Panoramica	3
2. Cosa riceverai e cosa serve da te	4
3. Passo 1 — firmare il token	4
4. Passo 2 — incorporare lo spazio	7
5. Ruoli, team e visibilità	8
6. Personalizzazione	8
7. API di sola lettura	9
8. Errori	11
9. Limiti e disponibilità	12
10. Sicurezza e privacy	12
11. Elenco di verifica prima di andare online	13

1. Panoramica

Sorso è un taccuino di degustazione del vino. Lo **spazio di team** ne è una versione pensata per i siti di club, enoteche e associazioni: lo incorpori nel tuo sito in un iframe e i tuoi utenti votano insieme i vini di una degustazione.

Ognuno vede i propri voti. Il **punteggio del team** di un vino è la media dei voti di tutti i partecipanti, e ciascuno lo vede **solo dopo aver votato quel vino**, per non farsi influenzare dagli altri.

Come funziona, in tre passi

Passo	Dove	Cosa succede
1. Firmare il token	Il tuo server	Quando un utente apre la pagina, il tuo server firma un token breve che dice chi è e a che team appartiene.
2. Incorporare	La tua pagina	La pagina contiene un iframe che punta a Sorso con quel token. Sorso lo verifica e apre lo spazio.
3. Leggere i risultati	Il tuo server (facoltativo)	Con la chiave API leggi elenco e risultati delle degustazioni, anche in CSV.

- **Non gestiamo utenti, password o inviti.** L'identità la garantisce il tuo sito: chi arriva con un token valido è chi tu hai detto.
- **L'API è di sola lettura.** Dall'esterno non si possono scrivere voti: si vota solo dentro l'iframe.
- **Non servono cookie.** Lo spazio non usa cookie né archiviazione del browser, quindi funziona anche dove i cookie di terze parti sono bloccati.

Come si vota

Per ogni vino l'utente sceglie tra due modalità, come preferisce:

- **Voto rapido:** tre giudizi — occhio, naso, bocca — ciascuno da 50 a 100. Il totale è la media pesata (10% occhio, 30% naso, 60% bocca).
- **Scheda completa:** nove giudizi da 0 a 10 sulle quattro fasi dell'esame (visivo, olfattivo, gusto-olfattivo, finale), convertiti nella stessa scala.

Entrambe producono un punteggio da **50 a 100**, quindi i voti dati in modalità diverse stanno nella stessa media. Il punteggio lo calcola sempre il server a partire dai giudizi.

Punteggio	Giudizio
50-59	Insufficiente
60-69	Sufficiente
70-79	Discreto
80-89	Buono
90-95	Eccellente
96-99	Eccezionale
100	Irripetibile (solo con ogni giudizio al massimo)

2. Cosa riceverai e cosa serve da te

Per ogni sito partner creiamo una configurazione. Ti consegniamo tre cose:

Cosa	A cosa serve	Dove tenerlo
ID partner per esempio club-vini	Identifica il tuo sito. Va nel claim iss del token e nell'indirizzo dell'iframe.	Non è segreto.
Segreto di firma 64 caratteri esadecimali	Serve a firmare i token. Chi lo conosce può far entrare chiunque nel tuo spazio.	Solo sul tuo server (variabile d'ambiente). Mai nel browser, mai in un repository.
Chiave API inizia con sk_	Serve a leggere i risultati dal tuo server.	Solo sul tuo server. Noi ne conserviamo solo l'impronta: se la perdi, se ne genera una nuova.

Consegna sicura. Il segreto e la chiave ti vengono mostrati una volta sola. Conservali subito in un gestore di segreti o nelle variabili d'ambiente del tuo server. Se pensi che siano stati esposti, chiedi la rotazione: la vecchia chiave smette di valere entro 30 secondi.

Cosa serve da te

- **I domini** dei siti in cui incorporerai lo spazio, solo con https:// (per esempio https://www.club.example). L'iframe funziona solo da questi: da qualunque altro sito il browser lo blocca.
- **Personalizzazione** (facoltativa): titolo, logo, colori, carattere, lingua. Vedi il capitolo 6.
- **Modalità di voto** consentite: voto rapido, scheda completa o entrambe, e quale proporre per prima.

3. Passo 1 — firmare il token

Il token è un JWT firmato con HS256 (HMAC-SHA256). Lo generi sul tuo server, a ogni caricamento della pagina, per l'utente che sta entrando.

I campi del token

Campo	Richiesto	Significato e regole
iss	sì	Il tuo ID partner.
sub	sì	L'identificativo dell'utente nel tuo sito. Da 1 a 128 caratteri tra lettere, cifre e . _ : @ -. Meglio un id opaco che un'email.
team	sì	Il gruppo dell'utente. Chi ha lo stesso team vede le stesse degustazioni; team diversi non si vedono. Da 1 a 64 caratteri tra lettere, cifre e . _ : -.
jti	sì	Identificativo unico di questo token (da 8 a 64 caratteri). Rende il token monouso: usalo una sola volta e genera un valore nuovo a ogni token.
exp	sì	Scadenza, in secondi Unix. Al massimo 15 minuti da adesso: consigliamo 5.
role	no	member (predefinito) oppure organizer. Vedi il capitolo 5.
name	no	Il nome da mostrare (fino a 60 caratteri). Non viene salvato: vive solo nella sessione.
lang	no	it oppure en. Se manca vale la lingua impostata per il tuo partner.

Regole da rispettare. Solo HS256 (qualunque altro algoritmo, compreso none, viene rifiutato). Il token vale **una volta sola**: generalo ogni volta che la pagina viene costruita e non metterlo in cache. Se l'orologio del tuo server va fuori tempo di più di un minuto, i token possono risultare scaduti: tienilo sincronizzato.

Esempio in Node.js

```
// Firma il token per un utente del tuo sito (Node.js, nessuna libreria esterna).
// Da eseguire SUL SERVER del tuo sito, mai nel browser: il segreto non deve uscire di lì.
const crypto = require("crypto");

const PARTNER_ID = process.env.SORSO_PARTNER_ID; // l'ID che ti abbiamo consegnato
const SEGRETO = process.env.SORSO_SECRET; // il segreto di firma (64 caratteri esadecimali)

const b64url = (v) => Buffer.from(v).toString("base64url");

function creaTokenSorso({ sub, name, team, role = "member" }) {
  const header = { alg: "HS256", typ: "JWT" };
  const payload = {
    iss: PARTNER_ID, // chi firma: il tuo ID partner
    sub, // l'ID dell'utente nel TUO sito (meglio un id opaco)
    name, // nome da mostrare, facoltativo
    team, // il gruppo: stesso team = stesse degustazioni
    role, // "member" oppure "organizer"
    jti: crypto.randomBytes(12).toString("hex"), // id unico del token: lo rende monouso
    exp: Math.floor(Date.now() / 1000) + 300, // scade fra 5 minuti
  };
  const corpo = b64url(JSON.stringify(header)) + "." + b64url(JSON.stringify(payload));
  const firma = crypto.createHmac("sha256", SEGRETO).update(corpo).digest("base64url");
  return corpo + "." + firma;
}

// Uso, nel codice che genera la pagina del tuo sito (a ogni caricamento, mai in cache):
// const token = creaTokenSorso({ sub: utente.id, name: utente.nome, team: "giovedì" });
// const url = `https://sorso-taccuino.vercel.app/embed?p=${PARTNER_ID}&token=${token}`;

module.exports = { creaTokenSorso };

if (require.main === module) {
  const [sub, team, role, name] = process.argv.slice(2);
  console.log(creaTokenSorso({ sub, team, role: role || "member", name: name || "" }));
}
```

Esempio in Python

```
# Firma il token per un utente del tuo sito (Python 3, solo libreria standard).
# Da eseguire SUL SERVER del tuo sito, mai nel browser.
import base64, hashlib, hmac, json, os, secrets, sys, time

PARTNER_ID = os.environ["SORSO_PARTNER_ID"] # l'ID che ti abbiamo consegnato
SEGRETO = os.environ["SORSO_SECRET"]       # il segreto di firma (64 caratteri esadecimali)

def b64url(dati: bytes) -> str:
    return base64.urlsafe_b64encode(dati).rstrip(b"=").decode()

def crea_token_sorso(sub, team, role="member", name=""):
    header = {"alg": "HS256", "typ": "JWT"}
    payload = {
        "iss": PARTNER_ID,          # chi firma: il tuo ID partner
        "sub": sub,                 # l'ID dell'utente nel TUO sito
        "name": name,              # nome da mostrare, facoltativo
        "team": team,              # il gruppo
        "role": role,              # "member" oppure "organizer"
        "jti": secrets.token_hex(12), # identificativo unico: rende il token monouso
        "exp": int(time.time()) + 300, # scade fra 5 minuti
    }
    corpo = (b64url(json.dumps(header, separators=(",", ":")).encode()) + "."
            + b64url(json.dumps(payload, separators=(",", ":")).encode()))
    firma = hmac.new(SEGRETO.encode(), corpo.encode(), hashlib.sha256).digest()
    return corpo + "." + b64url(firma)

if __name__ == "__main__":
    sub, team = sys.argv[1], sys.argv[2]
    role = sys.argv[3] if len(sys.argv) > 3 else "member"
    name = sys.argv[4] if len(sys.argv) > 4 else ""
    print(crea_token_sorso(sub, team, role, name))
```

Esempio in PHP

```
<?php
// Firma il token per un utente del tuo sito (PHP 7.4 o successivo, nessuna libreria).
// Da eseguire SUL SERVER del tuo sito, mai nel browser.

function base64url(string $dati): string {
    return rtrim(strtr(base64_encode($dati), '+/', '-_'), '=');
}

function creaTokenSorso(
    string $partnerId, string $segreto, string $sub, string $team,
    string $role = 'member', string $name = ''
): string {
    $header = ['alg' => 'HS256', 'typ' => 'JWT'];
    $payload = [
        'iss' => $partnerId,          // chi firma: il tuo ID partner
        'sub' => $sub,                // l'ID dell'utente nel TUO sito
        'name' => $name,              // nome da mostrare, facoltativo
        'team' => $team,              // il gruppo
        'role' => $role,              // "member" oppure "organizer"
        'jti' => bin2hex(random_bytes(12)), // id unico: rende il token monouso
        'exp' => time() + 300,        // scade fra 5 minuti
    ];
    $corpo = base64url(json_encode($header)) . '.' . base64url(json_encode($payload));
    $firma = hash_hmac('sha256', $corpo, $segreto, true);
    return $corpo . '.' . base64url($firma);
}

// Prova da riga di comando: php firma-token.php utente team [ruolo] [nome]
if (PHP_SAPI === 'cli' && realpath($_SERVER['SCRIPT_FILENAME']) ?? '' === __FILE__) {
    [, $sub, $team, $role, $name] = array_pad($argv, 5, '');
    echo creaTokenSorso(
        getenv('SORSO_PARTNER_ID'), getenv('SORSO_SECRET'),
        $sub, $team, $role ?: 'member', $name
    ), "\n";
}
```

4. Passo 2 — incorporare lo spazio

L'indirizzo dell'iframe ha questa forma:

```
https://sorso-taccuino.vercel.app/embed?p=ID_PARTNER&token=TOKEN_FIRMATO
```

Il tuo server lo costruisce a ogni caricamento della pagina, con un token appena firmato. Nella pagina:

```
<!-- La pagina del TUO sito che incorpora lo spazio di team. -->
<!-- L'indirizzo dell'iframe, con il token, lo genera il tuo server a ogni caricamento della pagina. -->
<iframe id="sorso" title="Degustazioni del club"
  src="https://sorso-taccuino.vercel.app/embed?p=ID_PARTNER&token=TOKEN_FIRMATO_DAL_TUO_SERVER"
  width="100%" height="700" style="border:0; max-width:640px"
  allow="" referrerpolicy="no-referrer"></iframe>

<script>
  // Facoltativo: l'iframe comunica la propria altezza, così eviti la barra di scorrimento.
  const ORIGINE_SORSO = "https://sorso-taccuino.vercel.app";
  window.addEventListener("message", (e) => {
    if (e.origin !== ORIGINE_SORSO) return; // ignora i messaggi di altri
    if (e.data && e.data.type === "sorso:height") {
      document.getElementById("sorso").style.height = e.data.height + "px";
    }
  });
</script>
```

Cosa succede dentro l'iframe

- Sorso verifica il token e lo scambia subito con una **sessione di 4 ore**, tenuta solo in memoria. Poi toglie il token dall'indirizzo.
- Se l'utente ricarica l'iframe (o dopo 4 ore) serve un token nuovo: l'utente deve ricaricare la tua pagina.
- **Altezza automatica.** L'iframe invia al tuo sito il messaggio { type: "sorso:height", height: numero }. Ascoltalo come nell'esempio, controllando sempre event.origin.

Se vedi “Questo link è già stato usato”

Il token è monouso, quindi succede quando lo stesso token arriva due volte. Le cause più comuni:

- la pagina è stata messa in **cache** (da te, da un CDN o dal browser) e contiene un token vecchio;
- un'**anteprima automatica** (un bot, un controllo dei link, il prefetch del browser) ha caricato la pagina prima dell'utente;
- il token è stato generato una volta e riutato per più pagine o più utenti.

Rimedio: genera il token lato server ad ogni richiesta della pagina e imposta Cache-Control: no-store sulla pagina che lo contiene.

5. Ruoli, team e visibilità

Il ruolo lo decidi tu, nel claim role. Sorso non ha schermate di amministrazione né inviti: se un utente è organizzatore lo dice il tuo sito.

Azione	Partecipante (member)	Organizzatore (organizer)
Vedere le degustazioni del proprio team	sì	sì
Creare una degustazione	no	sì
Aggiungere vini a una degustazione aperta	no	sì
Chiudere o riaprire una degustazione	no	sì
Votare, anche più volte lo stesso vino (l'ultimo voto sostituisce il precedente)	sì	sì
Vedere i propri voti nel dettaglio	sì	sì
Vedere la media del team di un vino	solo dopo aver votato quel vino	solo dopo aver votato quel vino
Vedere quanti hanno votato un vino	solo dopo aver votato	sempre (per sapere chi manca)

- **Degustazione chiusa:** i voti sono definitivi, non si può più votare né aggiungere vini. L'organizzatore può riapirla.
- **Team separati:** degustazioni e voti di un team non sono visibili agli altri team. Lo stesso sub in due team ha dati separati.
- **Limiti:** fino a 500 degustazioni per partner e 100 vini per degustazione. Nome della degustazione fino a 80 caratteri; vino fino a 100, produttore fino a 80, annata di quattro cifre oppure NV; note personali fino a 500 caratteri.

6. Personalizzazione

L'aspetto si adatta al tuo sito con pochi valori, che impostiamo noi per te. Inviaci quelli che vuoi cambiare:

Impostazione	Valori	Effetto
title	testo, fino a 40 caratteri	Titolo mostrato in alto.
logo	indirizzo https di un'immagine	Logo in alto, alto 32 px.
accent	colore #rrggbb	Colore dei pulsanti e della media del team.
bg	colore #rrggbb	Colore dello sfondo.
ink	colore #rrggbb	Colore del testo.
font	system, serif, rounded, mono	Carattere (tra quelli installati sul dispositivo).
lingua	it o en	Lingua predefinita; il claim lang la sovrascrive per utente.
modalità di voto	rapido, completa o entrambe	Quali modalità si possono scegliere e quale è proposta per prima.

Se imposti sia lo sfondo sia il testo, controlla che il contrasto sia sufficiente (almeno 4,5 a 1). Le immagini del logo devono essere servite in https.

7. API di sola lettura

Per leggere i risultati dal tuo server. Tutte le richieste vanno fatte **dal server**, mai dal browser: la chiave non deve uscire dal tuo sistema.

Cosa	Valore
Indirizzo di base	https://sorso-taccuino.vercel.app/api/v1
Autenticazione	Authorization: Bearer sk_ID_PARTNER_...
Formato	JSON, UTF-8. Ogni risposta porta X-Sorso-API-Version: 1 e Cache-Control: no-store.
Dati	Solo aggregati: mai chi ha votato cosa.

Elenco delle degustazioni

GET /api/v1/tastings?team=giovedì&status=closed

I filtri team e status (open o closed) sono facoltativi. Risposta:

```
{
  "tastings": [
    {
      "id": "efa74b5ecb",
      "team": "giovedì",
      "name": "Serata di ottobre",
      "status": "closed",
      "createdAt": "2026-10-07T19:16:42.668Z"
    }
  ]
}
```

Risultati di una degustazione

GET /api/v1/tastings/{id}/results

```
{
  "tasting": {
    "id": "efa74b5ecb",
    "team": "giovedì",
    "name": "Serata di ottobre",
    "status": "closed",
    "createdAt": "2026-10-07T19:16:42.668Z"
  },
  "minVotes": 2,
  "wines": [
    {
      "id": "a9c5c52f88",
      "producer": "Poderi Rivalta",
      "name": "Barolo Cannubi",
      "vintage": "2019",
      "votes": 3,
      "average": 88,
      "hidden": false
    },
    {
      "id": "936759882d",
      "producer": "Tenuta delle Sciare",
      "name": "Etna Rosso Contrada Rampante",
      "vintage": "2021",
      "votes": 2,
      "average": 74.5,
      "hidden": false
    }
  ]
}
```

```
{
  "id": "af3143b710",
  "producer": "Casa Marchigiana",
  "name": "Verdicchio Classico",
  "vintage": "2022",
  "votes": 1,
  "average": null,
  "hidden": true
}
```

Come leggere i risultati

- votes è il numero di voti; average la media del team, con un decimale.
- La media compare **dal secondo voto** (minVotes = 2): con un voto solo coinciderebbe con quello di una persona. Finché mancano voti, average è null e hidden è true.
- I punteggi dei voti rapidi e delle schede complete sono nella stessa scala 50-100, quindi la media li mescola correttamente.

Esportazione in CSV

```
GET /api/v1/tastings/{id}/results?format=csv
```

Un file da aprire in un foglio di calcolo. Le celle che iniziano con = + - @ vengono precedute da un apice, per impedire che un nome di vino venga eseguito come formula.

```
tasting_id,tasting,wine_id,producer,name,vintage,votes,average
efa74b5ecb,Serata di ottobre,a9c5c52f88,Poderi Rivalta,Barolo Cannubi,2019,3,88
efa74b5ecb,Serata di ottobre,936759882d,Tenuta delle Sciare,Etna Rosso Contrada Rampante,2021,2,74.5
efa74b5ecb,Serata di ottobre,af3143b710,Casa Marchigiana,Verdicchio Classico,2022,1,
```

Cancellare i dati di un utente

```
DELETE /api/v1/users/{sub}
```

Rimuove tutti i voti dell'utente (il sub che hai messo nel token) e aggiorna di conseguenza le medie. È pensato per le richieste di cancellazione. Si può ripetere senza effetti.

```
{
  "votesRemoved": 2
}
```

Esempi con curl

```
#!/bin/sh
# Esempi dell'API di sola lettura. Da eseguire dal SERVER del tuo sito.
# SORSO_BASE      indirizzo di Sorso, per esempio https://sorso-taccuino.vercel.app
# SORSO_API_KEY   la chiave API che ti abbiamo consegnato (inizia con sk_)

# 1. Elenco delle degustazioni (filtri facoltativi: team, status=open|closed)
curl -sS -H "Authorization: Bearer $SORSO_API_KEY" \
  "$SORSO_BASE/api/v1/tastings?status=closed"

# 2. Risultati di una degustazione (sostituisci ID_DEGUSTAZIONE con un id dell'elenco)
curl -sS -H "Authorization: Bearer $SORSO_API_KEY" \
  "$SORSO_BASE/api/v1/tastings/ID_DEGUSTAZIONE/results"

# 3. Gli stessi risultati in CSV, da aprire in un foglio di calcolo
curl -sS -H "Authorization: Bearer $SORSO_API_KEY" \
  "$SORSO_BASE/api/v1/tastings/ID_DEGUSTAZIONE/results?format=csv" -o risultati.csv

# 4. Cancellare i dati di un utente: usa l'ID che hai messo nel claim "sub"
curl -sS -X DELETE -H "Authorization: Bearer $SORSO_API_KEY" \
  "$SORSO_BASE/api/v1/users/ID_UTENTE"
```

8. Errori

Gli errori dell'API hanno sempre questa forma, con un codice stabile da usare nel tuo programma e un messaggio per le persone:

```
{
  "error": {
    "code": "unauthorized",
    "message": "Chiave API mancante o non valida."
  }
}
```

Stato	Codice	Quando
401	unauthorized	Chiave mancante, errata o di un partner disattivato.
400	invalid_status, invalid_user	Un parametro non è valido.
404	not_found	Degustazione inesistente o di un altro partner; percorso sconosciuto.
405	method_not_allowed	Metodo HTTP non previsto per quel percorso.
429	rate_limited	Troppe richieste. L'intestazione Retry-After dice fra quanti secondi riprovare.
503	read_only	Servizio in sola lettura per il limite mensile gratuito: le letture funzionano, la cancellazione no.
503	no_database	Servizio momentaneamente non disponibile.

Problemi frequenti con l'iframe

Sintomo	Causa probabile	Cosa fare
L'iframe è vuoto o mostra un errore del browser	Il dominio della tua pagina non è tra quelli registrati (il browser lo blocca: "Refused to frame").	Comunicaci il dominio esatto, con <code>https://</code> e senza percorso.
"Accesso non valido..."	Token mancante, firma sbagliata, scaduto o con campi non validi.	Vedi la tabella dei codici qui sotto.
"Questo link è già stato usato..."	Lo stesso token è arrivato due volte.	Capitolo 4: niente cache, un token per caricamento.
"La sessione è scaduta..."	Sono passate 4 ore, o la configurazione del partner è cambiata.	Ricarica la pagina del sito.
Un utente non vede le degustazioni degli altri	Hanno valori diversi nel claim team.	Usa lo stesso team per chi deve stare insieme.
Non compare "Nuova degustazione"	L'utente è member.	Metti role: "organizer" nel token.

Per capire perché un token viene rifiutato puoi inviarlo tu stesso (solo per diagnosi: questa chiamata è interna all'iframe e può cambiare). Attenzione: se il token è valido, questa prova lo consuma.

```
curl -sS -X POST https://orso-taccuino.vercel.app/api/embed \
-H 'Content-Type: application/json' \
-d '{"op": "session", "token": "IL_TUO_TOKEN"}'
```

Risposta con il motivo, per esempio:

```
{
  "error": {
    "code": "token_used",
    "message": "Token già usato: ricarica la pagina dal sito per ottenerne uno nuovo."
  }
}
```

Codice	Significato
malformed	Il token non ha tre parti o non è JSON valido.
alg	L'algoritmo non è HS256.
signature	Firma errata: segreto sbagliato o token modificato.
exp_missing, expired, exp_too_far	Scadenza mancante, già passata o oltre i 15 minuti.
not_yet	Il campo nbf è nel futuro.
partner	iss sconosciuto o partner disattivato.
claim_sub, claim_team, claim_jti, claim_role	Quel campo manca o ha un formato non valido.
token_used	Il token è già stato usato.
rate_limited	Troppi tentativi dallo stesso indirizzo.

9. Limiti e disponibilità

Cosa	Limite
Apertura di sessioni (/embed)	30 al minuto per indirizzo IP
Operazioni di un utente dentro l'iframe	90 al minuto per utente
API di sola lettura	120 richieste al minuto per chiave, e 120 al minuto per indirizzo IP
Sessione dell'iframe	4 ore
Validità del token firmato da te	al massimo 15 minuti, monouso

Servizio gratuito: cosa significa per te

Sorso gira su un'infrastruttura gratuita. Questo ha due conseguenze che è giusto conoscere:

- **Quota mensile.** L'archivio ha un limite di operazioni al mese. Oltre l'80% le risposte portano l'intestazione X-Sorso-Quota: warn (e gli organizzatori vedono un avviso nell'iframe); oltre il 95% il servizio passa in **sola lettura** fino al mese successivo: si può consultare ma non votare né creare. Per un uso normale (gruppi di qualche decina di persone) il limite è lontano: un voto costa circa 10 operazioni.
- **Nessuna garanzia di disponibilità.** Non c'è un impegno formale di continuità. Non è adatto a eventi in cui un'interruzione non sia tollerabile: scarica il CSV dei risultati al termine di ogni degustazione.

10. Sicurezza e privacy

Cosa devi fare tu

- Tieni il segreto di firma e la chiave API solo sul server. Se li pubblichi per errore, chiedi subito la rotazione.
- Firma i token solo per utenti già autenticati sul tuo sito, e imposta il team e il ruolo in base ai tuoi dati, mai in base a parametri della richiesta.
- Usa come sub un identificativo opaco del tuo sistema invece dell'email, quando puoi.
- Servi sempre la pagina che incorpora l'iframe in https.

Cosa fa Sorso

- La pagina si incorpora solo dai domini che hai registrato, non ha script inline, e non invia il riferimento della pagina di provenienza.
- Il punteggio lo calcola il server; i voti individuali non sono visibili a nessuno tranne a chi li ha dati, e l'API restituisce solo aggregati.
- Chi ha il token non può uscire dal proprio team né dal proprio partner: ogni richiesta controlla che team e partner coincidano.

Quali dati conserviamo

Dato	Conservato	Note
Identificativo dell'utente (sub)	sì	Serve a collegare l'utente ai suoi voti. Non c'è altra anagrafica.
Team, nome di degustazioni e vini	sì	Inseriti dagli organizzatori.
Voti, con modalità e giudizi	sì	Visibili solo all'autore; l'API espone soltanto le medie.
Note personali sui vini	sì	Visibili solo all'autore.
Nome visualizzato (name)	no	Resta nella sessione in memoria dell'utente.
Email, telefono, indirizzo IP	no	L'indirizzo IP è usato solo per il limite di richieste, in un contatore temporaneo.

- I dati restano finché non vengono cancellati: non c'è una scadenza automatica. Per cancellare un utente usa `DELETE /api/v1/users/{sub}` (capitolo 7).
- Chi gestisce il servizio ha accesso tecnico al database. Per l'informativa agli utenti e le basi giuridiche del trattamento valgono le valutazioni del tuo sito: quanto conserviamo è l'elenco qui sopra.

11. Elenco di verifica prima di andare online

Spunta ogni voce con una prova vera, non a memoria. Per qualunque dubbio o richiesta (nuovo dominio, rotazione dei segreti, tema, cancellazioni) rivolgiti a chi ti ha consegnato questa guida.

Verifica
☐ Ho ricevuto ID partner, segreto di firma e chiave API e li ho salvati solo sul server.
☐ Ho comunicato i domini esatti (con <code>https://</code>) e l'iframe si apre da quelli.
☐ Da un dominio non registrato l'iframe viene bloccato (prova da una pagina di prova).
☐ Il token viene generato a ogni caricamento della pagina e la pagina non è in cache.
☐ Un utente member vota e, solo dopo, vede la media del team.
☐ Un utente organizer crea una degustazione, aggiunge vini e la chiude.
☐ Due utenti di team diversi non vedono le rispettive degustazioni.
☐ Ricaricando solo l'iframe compare l'invito a ricaricare la pagina e la pagina, ricaricata, funziona.
☐ La lettura dei risultati dal server funziona e il CSV si apre correttamente.
☐ Ho provato la cancellazione di un utente di prova e le medie si sono aggiornate.
☐ Ho deciso chi, nel mio sito, è organizzatore e dove scarico il CSV al termine delle serate.
☐ L'informativa agli utenti del mio sito è aggiornata.